

Prague University of Economics and Business

Faculty of Informatics and Statistics



HUMAN FACTOR THREAT TO THE ICT SECURITY OF A COMPANY

BACHELOR THESIS

Study programme: Applied Informatics

Specialization: Applied Informatics

Author: Aliaksandra Karukina

Supervisor: Mgr. Ing. Tomáš Sigmund, Ph.D.

Prague, December 2023

Declaration of Authenticity

I declare that the Bachelor's Thesis presented herein is my own work, or fully and specifically acknowledged wherever adapted from other sources. This work has not been published or submitted elsewhere for the requirement of a degree programme.

Acknowledgement

I would like to express my sincere gratitude to my advisor Mgr. Ing. Tomáš Sigmund, Ph.D. for his valuable inputs into my thesis, as well as my family for their guidance and ongoing support throughout my Bachelor's degree study.

Abstract

In the rapidly advancing realm of Information and Communication Technology (ICT), this research investigates the often-underestimated threat posed by the human factor to the cybersecurity of companies. As organizations increasingly rely on advanced technological systems to protect sensitive data, vulnerabilities associated with human behavior become more pronounced. The primary objective is to comprehensively analyze the various dimensions of the human factor as a threat to ICT security.

Employing a multifaceted methodology that encompasses theoretical exploration, empirical research, and data analysis, the study seeks to shed light on specific ways in which human factors pose threats to ICT security. The research delves into social engineering, various attack methods employing the human factor, and a comparative analysis of these threats. Additionally, it explores the role of the human factor in information security, covering aspects such as awareness, skills, and organizational culture.

The empirical part of the study details the research design, methodology validation, and company-specific information used for analysis. Discussions synthesize the findings, emphasizing the significance of awareness, experience, negligence, and policies in shaping the human factor's impact on ICT security.

In conclusion, the research contributes actionable recommendations for organizations to fortify their defences against human factor threats in the dynamically evolving landscape of ICT security.

Keywords

ICT, security, human factor, phishing, cyber – attacks.

Contents

Introduction	9
1 Objective and Methodology	10
1.1 Objective	10
1.2 Methodology	10
1.3 Expected contribution	11
2 Theoretical part	12
2.1 Social Engineering	12
2.2 Types and methods of attacks using human factor	13
2.2.1 Phishing	13
2.2.2 Pharming	14
2.2.3 Spear Phishing	14
2.2.4 Wi – Fi phishing	15
2.2.5 Hoax	15
2.2.6 Vishing	16
2.2.7 Stolen identity	17
2.3 Comparing the threats	17
2.4 Human factor for information security	20
2.4.1 Information Security Awareness	22
2.4.2 Skills needed in ICT	23
2.4.3 Experience	23
2.4.4 Apathy	24
2.4.5 Incentive and disincentive policy	24
2.4.6 Negligence or ignorance	25
2.4.7 Stress	25
2.4.8 Budgeting	25
2.4.9 Culture	26
2.4.10 Communication	26
2.4.11 Security policy enforcement	27
2.4.12 Management support	27
3 Empirical part	28
3.1 Design of the research	28
3.1.1 Hypothesis/assumptions	28
3.1.2 Methods used for validation	29

3.1.3 Potential model without numeric values	30
3.1.4 Company's info	30
3.1.5 Demographical data of employees.....	31
3.1.6 Descriptive analysis of variables.....	32
3.1.7 Test of Fit – Model	35
3.1.8 Cronbach's alpha	36
3.1.9 Correlation Analysis	37
3.1.10 Parameters of the model	38
4 Discussions	41
4.1 Awareness and Experience as Significant Factors	41
4.2 Negligence and Ignorance	41
4.3 Incentive Policies and Budgeting.....	41
4.4 Communication and IT Department Support.....	41
4.5 Recommendations	42
Conclusions	43
List of references	44
Appendices	I

A List of Figures

Figure 1: Types of Likert scale..... 10

Figure 2: Human Factors for Information Security Management System21

Figure 3: Pearson correlation..... 29

Figure 4: Cronbach's alpha measure 29

Figure 5: Final Model with numeric values 39

Figure 6: Results of hypothesis40

A List of Tables

Table 1: Structure of attacks18

Table 2: Particular historical examples18

Table 3: Severity and possible consequences19

Table 4: Demographical data of respondents31

Table 5: Descriptive statistics..... 33

Table 6: Test of Normality 34

Table 7: log-in Normality 35

Table 8: Reliability test 36

Table 9: Parameters of the final model..... 38

Introduction

In the ever-evolving landscape of Information and Communication Technology (ICT) security, the human factor stands out as a significant and often underestimated threat to the cybersecurity of companies. As organizations increasingly depend on advanced technological systems to safeguard sensitive data, vulnerabilities associated with the human element become more pronounced. This research aims to thoroughly explore the intricate dynamics of the human factor as a threat to ICT security within a company.

The primary objective is to analyse the various dimensions of the human factor as a threat to ICT security. A multifaceted methodology, including theoretical exploration, empirical research, and data analysis, is employed to achieve this objective. Anticipated contributions lie in illuminating specific ways human factors pose threats to ICT security. Understanding social engineering, attack methods, and factors influencing human behaviour allows organizations to develop targeted and effective cybersecurity strategies.

The theoretical part delves into social engineering, attack methods using the human factor, and a comparative analysis of these threats. It explores the human factor's role in information security, covering aspects such as awareness, skills, and organizational culture.

The empirical part details the research design, methodology validation, and company-specific information for analysis. Discussions synthesize the findings, emphasizing the significance of awareness, experience, negligence, and policies in shaping the human factor's impact on ICT security.

In conclusion, the research provides actionable recommendations for organizations to fortify defences against human factor threats in the evolving ICT security landscape.

1 Objective and Methodology

1.1 Objective

The primary objective of this research is to comprehensively analyze the perceptions of cybersecurity among employees within a company and to identify the predominant factors contributing to the occurrence of successful cyber-attacks. The study aims to delve into the intricate dynamics of how employees perceive cybersecurity as a phenomenon, exploring their understanding of potential threats, their awareness of security measures, and the factors that influence their behavior in the digital realm.

1.2 Methodology

The whole research is approached with two different ways, theoretical background that depicts the previous research in regards of cyber security and cyber-attacks. The theory depicts the common ways of such attacks and how unaware and at the same time vulnerable people are to such attacks.

The empirical part is based on online questionnaire that is distributed in a Czech company (TBM Group) and its employees. There are over 25 of questions to be asked that form a certain composite variable (See, [Survey – Design](#)). The author applied the Likert – Scale method to evaluate the responses of participants to a certain statement.

The Likert scale, developed by renowned American social scientist Rensis Likert (1930), is a widely utilized method in survey research, See *Figure – 1*. The survey instrument employs a response scale consisting of either five or seven points to assess the thoughts or emotions of participants. Participants have the option to select a response that is either negative, neutral, or positive in relation to a given statement.

Figure 1: Types of Likert scale

Type	1	2	3	4	5
Agree/Disagree	Strongly disagree	Disagree	Neither agree not disagree	Agree	Strongly agree

Source: Tsang (2012). KK. The use of midpoint on Likert scale: The implications for educational research. Hong Kong Teachers Centre Journal. 2012;11:121-130

Stated hypothesis

If a company trains or runs a course for employees that helps to identify the cyber – attack, there is a higher probability that such company will get into trouble, hence, the author states the following hypothesis.

H0: There is a positive correlation between the experience of a user and privacy concern of a firm.

H1: There is none - positive correlation between the experience of a user and privacy concerns of a firm.

H0: There is a negative correlation between the “Negligence and Ignorance” of a user and privacy concern of a firm.

H1: There is none negative correlation between the “Negligence and Ignorance” of a user and privacy concern of a firm.

H0: There is a positive correlation between the “Incentive policy and budgeting” and “Privacy concerns of a firm”.

H1: There is none - positive correlation between the “Incentive policy and budgeting” and “Privacy concerns of a firm”.

1.3 Expected contribution

The primary objective of this contribution is to enlighten readers about various potential cyber-attacks that individuals may encounter while using computers/*wifi connections and other devices in the workplace*. It emphasizes the consequences that may arise when protective measures are inadequate, leading to a lack of awareness. The focus of the work will predominantly be on transforming employee education, modifying tasks, restructuring the organizational framework of the IT department and IT security department, and aligning private company regulations with state laws and specific norms such as ISO 27001. Ultimately, the author suggests an effective plan aimed at mitigating the occurrence of cyber-attacks within organizations.

2 Theoretical part

2.1 Social Engineering

Social engineering is a method in which the attacker exploits the human characteristics of a victim, particularly human weaknesses and inattention. The aim of the attacker is to deceive or confuse the victim while posing as an authorized person (William and Mitnik, 2002, p.55). The victim believes that they are providing personal or company information to an authorized person and does not consider that the attacker's goal may be to misuse this information (ibid).

There are many techniques and facts that can help the attacker to be very successful. For example, the first technique can be to consider the authority. When the attacker pretends to be someone who is generally considered an authority figure in public, they can gain access to any information. There was even an experiment conducted in a hospital in the USA where a fictional doctor called a nurse and asked her to give some medication to a patient. Although the nurse knew that the dose of the medication was too high, she did not hesitate to obey the authorized person just due to their title of a doctor. Of course, the researchers stopped her. It means that if the attacker pretends to be some important person, it can help them a lot. (The "Social Engineering" of the Internet, 2012).

Another possibility is to aim at the victim's feelings. Sometimes attackers can send an email asking for some money for an ill person or another kind of charity. Then they ask for information about the victim's bank account and the goal is reached. Next, they can pretend to be a colleague and ask for help. Again, they discuss, and the attacker gains internal information (William and Mitnik, 2002, p.56). Experience in psychology is required rather than just IT knowledge. Another possibility is to ask for the victim's participation in some competition, asking for their vote. They ask for some information, or just via a link, they can infect the computer (ibid). There are many other techniques, and they differ from user to user. The different character of each person and their awareness and attention is the reason why many attacks are not successful at 100%. The socioecology never works at 100%, although it can be prepared technologically without any mistakes (Bruce, 2000, p. 18).

The first possibility is again to pretend to be some authorized person. It can be, for example, someone from the IT department asking for access to computer folders, or a manager or supervisor. Of course, this only works in larger companies where people do not know each other very well. Various techniques and devices such as email, mobile, or others can be used. (William and Mitnik, 2002, p.57).

In a company, fellow feeling also works. A colleague asks for help from another colleague and pretends to be desperate. This type of attack must be well-prepared as the attacker needs to know the responsibilities and tasks of specific employees and ask for information that they should know. In this case, it is important to act worried and lost and make the other colleague feel sorry for the attacker. (Hatch. et. el., 2003).

Somewhere between these two types is an attack when the attacker pretends to be a worker of the IT department and needs access to an employee's computer to see if everything is working well or to control something. Employees trust IT specialists, and very often they do not know them personally, so they cannot recognize that the wrong person is speaking. If they allow the attacker to enter the computer, it is up to the attacker's knowledge and abilities to determine what information they get. Thus, the social engineering is a such an effective tool to implement as it does bypass the technological protection. In the case of sociotechnical attacks using emotions and authority, there is no specific protection. The only way to protect oneself is to be aware and not trust anyone when giving away important information.

2.2 Types and methods of attacks using human factor

In the following chapter, the most common methods of attacks that use the human factor will be described. This means that they are created by people and are intended to harm the victim by exploiting their inattention and irresponsibility. Attackers can gain access to a company's systems through a user and obtain internal data, destroy data or systems, or harm the company in various ways (for example, by stopping production).

The following attacks are the basic ones that attackers use and develop new methods for every day. Due to their rapid development, these threats are very dangerous and unpredictable.

2.2.1 Phishing

In the past, it was known as carding. Later, the name phishing was created using the first and last letters in the description - **P**assword **H**arvest **F**ishing. In a few words, the aim is to get as many passwords as possible. The second name is also branding spoofing, which is the falsification of some famous brands. The connection to the brand is because attackers often use the names of brands to obtain information from users.

There are two types of phishing. The basic one is email phishing, which uses the easiest and most common way of communication – email. The user receives a false email that seems trustworthy. Then, there is a link to a false web page that requires the user to share personal information or passwords, which is then misused by attackers for several purposes. The second type is malware phishing, which is much more complicated, and the attacker must be more experienced. This type uses some kind of virus that infects the user's computer via a link on which the user clicks. Then, all passwords and information are automatically sent to the attacker. The passwords are noted by a key logger and then sorted so that the attacker gets only the information useful to sign in to a user's account.

All around the world, there was an attack in 2022. The email was from Amazon, which looked very similar to the famous Amazon, a company selling books. The email was offering some books and discounts, and there was even a very similar logo. The user used the link to sign up for Amazon to get some discount, and by doing so, the computer was infected. The second example, which has been happening in recent years, is a false login page for Google Drive. For this, it is recommended to use two-factor authentication to verify the user (Toohill, 2023). And there are many others.

The problem with phishing is that there are two parties that suffer from this attack. The first one is, of course, the user. If the user protects themselves, it is only an annoying message. If they are not careful, they can lose some money or their identity online. The second party is companies and brands whose names are misused in the "campaign" of phishing.

Phishing is, of course, a criminal incident. Even for professionals, it is very difficult to recognize this type of crime. Attackers often simulate the real message from the company, making it very difficult to identify the false message.

In this case, the biggest problem among users is their weak responsibility. People are not aware enough of possible threats when clicking on an unknown link.

2.2.2 Pharming

Pharming is very similar to phishing, and the name was created by combining the words "phishing" and "farming." The entire system of this attack is based on the DNS domain, which translates the name of the domain from the URL into an IP address. The advantage of the DNS domain for users is that they do not have to remember the numerical addresses.

The attacker rewrites its records and connects different numbers to the names of pages, redirecting the user to another page (Hewwit, 2020, p.11). So, when the user types the name of the domain they want to visit, the request goes to the DNS server. The attacker intercepts this request and redirects the user to their own server, which can be used for advertising or more nefarious purposes. Often, false pages of banks are used to obtain personal information from users, and the user is unable to visit the server they intended to.

If the user does not protect themselves with some antivirus system or sorting of emails and, moreover, is not aware of some strangely looking messages and emails and gives away their personal details to all pages, it can be very dangerous. Statistics say that there are 25 million phishing messages every single day, and only 1% of them reach their goal, which is to obtain personal information (Lance, 2007, p.15)

The problem with phishing is that there are two parties that suffer from this attack. The first one is, of course, the user. If the user protects themselves, it is only an annoying message. If they are not careful, they can lose some money or their identity online. The second party is companies and brands whose names are misused in the "campaign" of phishing. Phishing is, of course, a criminal incident. Even for professionals, it is very difficult to recognize this type of crime. Attackers often simulate the real message from the company, making it very difficult to identify the false message. In this case, the biggest problem among users is their weak responsibility. People are not aware enough of possible threats when clicking on an unknown link (Požár, 2019).

2.2.3 Spear Phishing

Spear phishing is based on the same practice as phishing; however, it is targeted to a specific group of people or companies. It appeared as a reaction to the decreasing effectiveness of mass phishing (Hewwit, 2020, p.12). The target group is defined geographically or is a particular company. To target the group, spear phishing often uses information that is interesting to the target group or some information regarding finance.

Spear phishing appeared as a reaction to the decreasing effectiveness of common phishing, which is applied massively (Hewwit, 2020, p.13). This massive phishing message was too general to be believable. On the other hand, it is much more difficult to prepare such an attack. It requires very long and proper preparation. The attacker must collect much information that is available about the given company (ibid). Then the attacker acts as an internal employee and sends an email to external customers or internal employees. The email is very well prepared, and people believe it. It is also addressed to the given person. When they do not recognize the email, very often they give the attacker their details and passwords. Around 10% of recipients become victims.

2.2.4 Wi - Fi phishing

Wi-Fi phishing is one of the very famous phishing methods. As the name implies, in this attack, Wi-Fi access is used. The attacker creates a malicious Wi-Fi access point that appears to be a verified public Wi-Fi access point. Users connect to the point believing it is a common free Wi-Fi point. As soon as the victim connects to the network created by the attacker, they have free internet connection while the attacker has free access to all the victim's data. The Wi-Fi point looks very similar to other secure Wi-Fi points. It can also use some company information and create a Wi-Fi point inside the company so that the users from the company (employees) connect to the new network created by the attacker and the attacker can get confidential information from the given company.

It is one of the most dangerous attacks as it can deceive many people, not only the target group. This method allows the attacker to gain access to all the victim's information. It can gain access to the whole device, not only passwords and systems but also documents.

When it is created within some company, it can be very serious as the access to all internal data and information can be revealed.

On the other hand, it is very complicated to get into a company and create some Wi-Fi access that seems real and confidential. But when they do so, they can steal information very quickly. Only 5% of mobile devices were able to protect data when connecting to the attacker's Wi-Fi. In the case of computers with installed protection programs, still only 60% were able to recognize threats of the wrong Wi-Fi. (Wi-Fi Phishing Explained, 2022).

2.2.5 Hoax

A hoax is defined as a message spread by internet users and not by any robots or viruses. It is a false and alarming message. It can be some kind of gossip or a false message created to harm someone. The aim is to frighten users or change their minds about something. The distribution is based on users themselves. There is no program to do it. Users just send it to each other as they find the messages interesting or unbelievable. There are more types of threats which use false alarm messages:

- Virus warning - this is the most often spread via some kind of messenger. The message warns of a virus which the users can activate by opening some message or adding some new contact. Then the users are more aware and do not believe new people who add them even though they are truly people and friends.

- Fake plea for help - this message misuses emotions. It can be a message speaking about someone ill or after an accident and asking for help from users by spreading the message.
- Rumors and gossip - the most often used type of hoax which is used to harm some company or person. It can be a fake message about some celebrity or about some product which is harmful for users or, on the other side, very good.

The recent very famous example was when a hoax was used in the campaign of the presidential election in the Czech Republic. During the last week of the final round, a message appeared on the internet that one of the two candidates had died. It was, of course, a false message. The next example is an email which speaks about Microsoft and its connection to Internet Explorer. It is very interesting that this email first appeared in 1999 and it still annoys many users. If the receiver opens the email, it is not dangerous for the appliance but annoying for the users who waste time reading it. With the development of social media, it is still more common that hoaxes are focused on celebrities, famous people, politics, and public personalities in general.

Hoax is not as dangerous as the others. Actually, it is not dangerous at all for the common user, but very annoying and time-consuming. But it should not be taken lightly as these messages can deeply harm someone's image and personality.

Hoax messages can also be used for gaining profit. For example, via a hoax message, some stakeholder convinces people to buy the company's shares. Then the value of the company rises, and the given person who has spread this hoax sells his share, which is overvalued. After a while, the value of the company comes back to the previous level as there was nothing new or any change, which people believe in.

2.2.6 Vishing

Vishing is the next type of phishing previously presented. This attack uses the so-called VoIP, which is the name for internet calling services such as Skype or Messenger. The principle is the same as before, pretending to be the identity of a bank or company, but the difference is that the contact between the attacker and the victim is via phone or a calling application.

The first step for the attacker is to create a false number that looks similar to the real number of a bank or another institution or company. When the victim dials the given number, they are redirected to the phone of the attacker. Then the victim is asked again to share personal information and passwords. One of the possible messages is "Your account was blocked" or "You need to change your password." The user gives away personal data much easier because they believe it. When the attacker calls, the victim doesn't think that it could be dangerous and doesn't ask for any information or verification. If they do ask, the automated system on the other side of the phone will not respond. There is often no real person but an automated system that repeats the same phrase. When the user tells their password, the attacker uses it as soon as possible to get into their account and then into other accounts and profiles.

One of the most widespread and successful attacks was during the COVID-19 pandemic when victims received calls or messages about where to go to be tested. The attacker pretended to be a governmental officer and led people to a page with "GOV" in the name. As they downloaded the application with testing places, they also downloaded a virus that was stealing their details.

Just like phishing, vishing is also very dangerous. It is more complicated, but on the other hand, when the attacker pretends to be someone else very well, the victim just cannot recognize it. (Jiřík, 2022)

The problem is that mobile devices cannot protect themselves, and users do not notice anything wrong so quickly. As a consequence, only 3% of attacked mobile devices manage to protect themselves and users' data (Verizon, 2020).

2.2.7 Stolen identity

Stealing someone's identity is a criminal attack committed to gain profit. The attacker obtains personal information about the victim and pretends to be them. It's a long process during which the attacker collects personal information, mainly from social websites or other online activities of the victim. Then, under the victim's name, the attacker can buy things, close agreements, and ask for loans. No one knows that the user is false, and when it comes to paying or fulfilling other obligations connected to the attacker's actions, all duties fall on the victim. Although victims often don't know what's happening, they must face all accusations and degradation (Krádež identity na internetu, 2020).

A famous and ironic example happened in 2020. The victim was the club Nelež, which fights against disinformation on the internet. The attacker set up a false Facebook profile based on public information about the club. Then they did the opposite of the club's aim and spread false information, harming the name of Nelež (Krádež identity na internetu, 2020).

The biggest case of stolen identity was revealed in 2008 in the USA. Local offices found out that a group of five people hacked into banks' systems and stole personal and financial information about their clients (Úřady v USA odhalily největší krádež identity v historii internetu, 2009).

The biggest problem is that victims are often unaware that they are victims of this crime. It can affect not only their bank accounts but also their entire lives. Attackers can apply for jobs, ask for loans, and establish personal relationships. It depends on the attacker's goal.

On the other hand, it can also be focused on a bigger group, as in the example of the attack in the USA. The victim often finds out when it's too late, and great damage has been caused. For example, in 2014, there were 30 attacks on the Wall Street market (Collins, 2015), and in 2020, the number doubled.

2.3 Comparing the threats

This chapter briefly describes each threat in separate tables, focusing on their structure, examples, protection, and severity. The comparison is conducted by the author herself based on obtained secondary data demonstrated in previous chapter.

The first table compares the threats from the attacker's point of view, considering their structure and the process of creation. The structure of the attack explains how it works, and the difficulty for the attacker to create and realize a given type of attack. In other words, it can be called the cost (time, money) for the attacker, as well as their demands.

Table 1: Structure of attacks

Method of attack	Structure
Pharming	Changing DNS server in order to redirect the user to a false web page where they are prompted to enter their password.
Phishing	Email phishing involves mass email sending that contains a link to a false webpage that prompts the user to enter their password. The second type is malware phishing, which involves infecting the user's computer and copying all their passwords and information.
Spear Phishing	This type of phishing targets a specific group of people and requires longer and proper preparation. The email is much more specific and believable.
Wi-Fi Phishing	Next type of phishing uses public Wi-Fi networks. When the user connects to it, they get free Wi-Fi in exchange for all their data and passwords.
Hoax	It is a simple message that is not true. It can harm a person's or company's image, or the aim is just to confuse users.
Vishing	Vishing is a type of attack which is based on the same principle as phishing, but it uses phone calls to gather the user's information.
Stolen identity	This method involves long-term observation and deep investigation of the targeted person. The attacker gathers information from the user's social media profiles.

Source: Source: (Jiřík, 2022; Verizon, 2020)

When it comes to the structure, five out of seven methods aim to obtain personal information and passwords of the victim, which can be used to access bank accounts or other accounts. Pharming and Wi-Fi phishing require the attacker to be proficient in IT technologies to create a false Wi-Fi point or DNS server. Spear phishing and stolen identity require the attacker to observe the victim for a significant period of time. The easiest to create is the hoax, which aims to harm someone's image without obtaining any information.

The second table will summarize some world-known examples of each attack. The examples were chosen based on their severity for society, as well as for a given company or even state.

Table 2: Particular historical examples

Method of attack	Example

Pharming	50 companies in the financial sector were the target of an attack in 2007.
Phishing	A false company called "Amazon" (similar to the real Amazon) was offering a book via email in 2022.
Spear Phishing	A false email from the American financial office was sent to users who were in contact with that office in 2005.
Wi-Fi Phishing	In 2020, the US Department of the Interior's internal system was targeted by this attack. It showed that the internal system was not secure at all.
Hoax	In 2023, during the presidential election, news appeared that one of the candidates died.
Vishing	In 2020, attackers took advantage of the COVID pandemic and pretended to be governmental pages regarding testing and obtained information from people.
Stolen identity	The biggest was in 2008 in the USA when attackers stole information from banks.

Source: (Jířík, 2022; Verizon, 2020)

There were many attacks, but often people are ashamed so they do not report them. Moreover, when they are individuals, there is not much information about it. Attacking a bigger company requires much more skills, experience, and time. It is also much riskier if the attacker is caught. The severity is evaluated according to the possible effect, mainly aiming to steal money or harm someone's or a company's image. The severity also equals the success rate of the given attacks.

Table 3: Severity and possible consequences

Method of attack	Severity	Classification
Pharming	Can be very annoying when redirecting to a false page. The victim page can have a bad reputation as a consequence. If it gets information about the bank account, it can be very serious.	Identity theft, personal information
Phishing	Can affect users as well as companies whose name is used. Common phishing is not so effective as users very often recognize it.	Identity theft, scanning of information.
Spear Phishing	It can be very serious if the user believes the page and gives out his personal details.	Identity theft.

Wi-Fi Phishing	If it is created correctly, it can get into the user's device and get all the information, including passwords.	Identity theft, falsification
Hoax	It can harm only image and competitiveness.	
Vishing	Nowadays, it is not used so often as mobile calls are not so common. If the user gives his information, he can be robbed as well.	Identity theft.
Stolen identity	It can be dangerous for the bank account but also for the victim's image and his health when he is stressed from being stalked.	Identity theft, personal information

Source: (Jířík, 2022; Verizon, 2020)

All of the attacks, except for hoax, are mainly created to get some money. So, when it comes to stealing money, they can be very serious. Stolen identity can also affect the victim's physical health as stalking can be very unpleasant. All the attacks can also seriously affect the image of some company. That basically means that financial loss and damages can be much higher as a consequence of a broken image. However, it is challenging to evaluate things like know-how or image. Moreover, the price of some brand is automatically known and regularly reevaluated only at the biggest companies.

2.4 Human factor for information security

The individuals involved in the design and utilization of technological products occupy a crucial role. They have the potential to either contribute positively or pose a risk. Consequently, it is imperative for organizations to effectively manage the human factors associated with accidents involving information systems. Several studies have emphasized the increase in human-related security incidents (Lee & Lee, 2002; Willison, 2006). Within the framework of any organization, rules, requirements, processes, and codes of conduct are formulated with the purpose of guiding individuals in their adherence to established guidelines. Individuals serve as implementers of policies. The role of human behavior is a significant determinant of the success or failure of a security system (Islam and Dong, 2008). According to Sarker (Sarkar et al., 2010), it has been argued that technology solutions alone are insufficient in addressing insider risks, as these vulnerabilities are essentially rooted in human behavior. The available research unequivocally demonstrates that the role of human factors within Information Security Management Systems (ISMS) has been neglected and insufficiently cultivated. Information security incidents that occur due to human engagement can be categorized as either deliberate or thoughtless actions (Mouratidis, 2008). In all instances, the human function encompasses two distinct dimensions: cognitive proficiency (knowledge) and individual disposition (character). A comprehensive list of parameters supporting each dimension was identified and categorized, as depicted in Figure 2. In the present study, direct factors refer to those that primarily rely on specific individual traits and exert a substantial influence on the Information Security Management System (ISMS). Indirect variables are contingent upon external factors, namely organizational considerations such as sufficient budget allocation

and effective policy implementation. These external elements exert influence on both the direct factors and the Information Security Management System (ISMS).

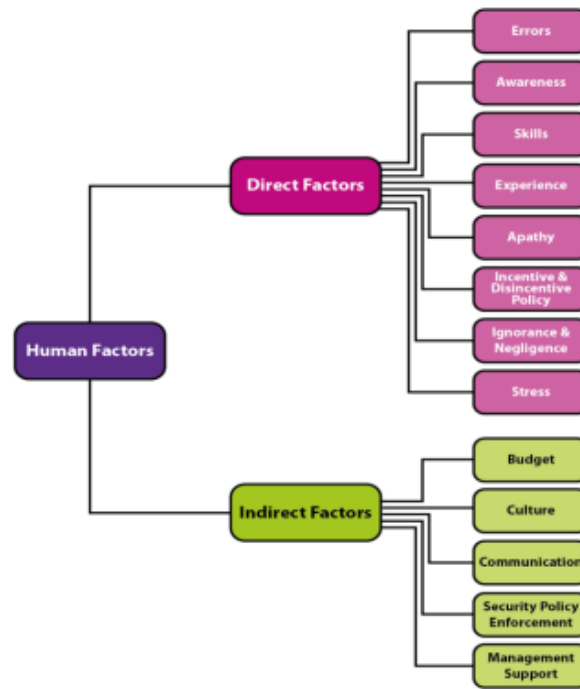
Direct Factors

As previously mentioned, these elements exert a direct influence on Information Security Management Systems (ISMS). These factors mostly rely on the unique attributes of each individual. This section presents a comprehensive analysis of the aforementioned criteria.

Errors:

The term "error" can be conceptualized as a deviation inside a system that operates with precision and accuracy (Avizienis et al., 2004). Cases involving Information Systems (IS) frequently occur with a rigorous technical approach, yet fail to consider the influence of human behaviour (Besnard and Arief, 2004; Rescorla, 2003). For instance, a password validation policy mandates individuals to select a password that is intricate in nature. It is probable that it would consist of a sequence of characters, including at least one uppercase letter and numerical digits, which may pose challenges for certain users in terms of memorization. Consequently, individuals resort to recording their passwords in vulnerable locations, such as their notebooks, which may be susceptible to unauthorized access. Hence, it is imperative to give careful consideration to the responsibilities of individuals in information systems policies. Human errors can be categorized as either intentional or unintentional. However, according to Kraemer and Carayon (2007), there is a belief that human errors can be attributed to a lack of care and unintentionally contribute to the inadequacy of Information Security Management Systems (ISMS). The analysis determined that human errors can be attributed to indirect factors, specifically communication and security culture. Human errors can pose challenges to the implementation of the ISMS, despite its robust technical infrastructure. According to Cobb et al. (2002), it can be argued that various technical measures are susceptible to being circumvented due to human errors. The security policies are formulated with the intention of regulating behaviour in order to mitigate the occurrence of errors. However, the definition, measurement, and management of behaviour pose substantial challenges within any organizational context.

Figure 2: Human Factors for Information Security Management System



Source: Bulgurcu, Cavusoglu & Benbaasat (2009)

2.4.1 Information Security Awareness

Awareness is an initiative designed to foster a comprehensive understanding of individual obligations inside organizations, serving as a central focus within the Information Security Management System (ISMS). For instance, consumers are encouraged to promptly report any potentially questionable electronic message they may receive. The language of Information Security Awareness (ISA) pertains to individuals' comprehension and awareness of Information Security Management Systems (ISMS) through the lens of security policy. The potential for misinterpretation and misunderstanding of the security policy underscores the significance of an awareness programme, which is equally relevant in relation to other information security measures. The significance of some variables, such as the clear delineation of roles and duties, which need employees' knowledge in awareness programs, was underscored in the NIST report by Wilson and Hash (2003). The favourable impacts of awareness programs on the effectiveness of Information Security Management Systems (ISMS) have been widely acknowledged in the literature (Kraemer and Carayon, 2006; Redmill, 2009). Organizations demonstrate a high level of concern regarding their staff's compliance to information security protocols, including the implementation of security policies (Puhakainen, 2006; Ernst & Young, 2008). However, several studies have raised concerns about the present approaches to IS security awareness, citing the lack of robust rules and insufficient theoretical justification (Siponen, 2000; Aytes & Connolly, 2003; Puhakainen, 2006). Hence, it is evident that an absence of research exists pertaining to the development of more efficient and comprehensive ISA programs. Moreover, despite the considerable importance of awareness, there is a lack of empirical research to assess the influence of the awareness component on information security (Bulgurcu et al., 2009).

2.4.2 Skills needed in ICT

Skills are essential for the successful execution of job responsibilities and significantly contribute to the overall effectiveness of human performance. Education and training play a pivotal role in the cultivation of abilities and the manifestation of dedication to upholding professionalism and competence. Skills have a significant role in addressing IS concerns, particularly in the context of incident response (Werlinger et al., 2009). The deficiency of sufficient and suitable personnel with the necessary skills is a contributing factor to the subpar implementation of information systems policies (Kreamer et al., 2006). Skill proficiency is a significant factor in addressing all facets of ISMS, as highlighted by Mead et al. (2000). It is imperative for employees to possess sufficient capabilities in order to effectively address the demands of the information security policy. For example, in the event that individuals within a sales department lack proficiency in utilizing the E-mail encryption feature, they may inadvertently transmit unencrypted electronic communications to consumers, thereby compromising the confidentiality of sensitive information. The potential vulnerability of sensitive information may lead to its public exposure and subsequent acquisition by malicious actors. It is imperative to avoid both overestimating and underestimating individuals' skills (Herzog, 2010). Organizations should not exclusively prioritize those with comprehensive technology proficiency. According to Briggs and Edwards (2006), in order to effectively address the difficulties posed by IS and achieve organizational objectives, it is essential to carefully consider a range of criteria encompassing both business and technology when selecting training programs. The significance of the issue is heightened as corporate conduct undergoes rapid transformation as a result of emerging technical advancements (Leek et al., 2003). In order to effectively navigate the rapidly evolving business landscape, it is imperative for organizations to possess a high degree of adaptability.

2.4.3 Experience

The inclusion of subjective experience plays a significant role in the acquisition and development of human knowledge (Chalmers, 2004). Researchers hold divergent perspectives regarding the role of "Experience" within the framework of the ISMS concept. There are scholars that contend that individuals' comprehension of the concept and methods of Information Systems (IS) is influenced by several aspects, such as their personal experiences (Kraemer, 2006; Simon et al., 2009; Vance, 2010). According to Kraemer (2006), there are reasons that assert the crucial role of individuals' expertise and expertise in the successful execution of an Information Security Management System (ISMS). The aforementioned experts claim that experience is a crucial requirement for an Information Systems (IS) team. The authors contend that the presence of inexperienced employees and inadequate instruction pose significant risks to the security of digital assets. According to Briggs and Edwards (2006), the effectiveness of security behavior is mostly influenced by factors such as individuals' interpersonal skills, managerial abilities, and social competencies, rather than their level of experience in the field of security. While there exists a divergence of opinions regarding the extent of impact exerted by the aspect of experience, it is universally acknowledged by both sides of the issue that experience does indeed play a significant role. This difficulty can be elucidated by the use of an illustrative example. A novel access control mechanism has been implemented to restrict the dissemination of information, thereby safeguarding corporate trade secrets and other sensitive data. The

imposition of this requirement may present a significant challenge for employees, as it appears to be in conflict with established practices. Hence, the individuals' encounter with unrestricted dissemination of knowledge is compromised by the implementation of the novel policy.

2.4.4 Apathy

Apathy within an organizational environment refers to the lack of motivation or enthusiasm exhibited by employees towards the goals and objectives of the organization, which ideally should be accompanied by pro-social behavior (Thomson & Niekerk, 2012). The presence of apathy inside organizations poses considerable challenges as it hinders the willingness to effectively perform organizational procedures. The lack of interest or concern exhibited towards the procedures and rules of ISMS (Information Security Management System) results in a state of uncertainty regarding the duties outlined in the security policy. According to Kabay (2002), it fosters a work atmosphere where people perceive themselves as having no obligations. According to Bartol and Martin (1994), positive attitudes, motivations, and favorable work environment are factors that contribute to improved performance. Conversely, apathy and unresponsiveness have been found to result in bad outcomes. In the study conducted by Siponen (2000), the author posited that a positive attitude plays a crucial role in enhancing the efficacy of a security system. Nevertheless, the measurement of attitude and motivation presents significant challenges. According to Thomson and Niekerk (2012), it has been posited that the occurrence of miscommunication between employees and senior management might result in misunderstandings, ultimately leading to a sense of indifference among employees. It is worth mentioning that inside organizations characterized by a coercive atmosphere, employees tend to experience feelings of frustration and dissatisfaction (Schein, 1992; Layton, 2005).

2.4.5 Incentive and disincentive policy

In some cases, individuals employed in corporate contexts may unintentionally neglect to sufficiently prioritize compliance with security regulations. To explicate the phenomena of users' indifference and ignorance, an examination of software piracy can be undertaken. This manifestation occurs when employees possess a limited comprehension of software installation due to several circumstances, including insufficient training. The majority of incidents consist of unintentional breaches (Vroom and Solms, 2004). The quick and effective reaction required in response to the repercussions of ignorance or negligence in Information Security Management Systems (ISMS) calls for the involvement of experts who possess expertise in the field of privacy and security. Organizations spend significant amounts of money towards the improvement of their IT systems as a means of addressing this particular challenge. Nevertheless, the matters of ignorance and negligence are intrinsically rooted in human behavior and require a unique strategy for their resolution. The process of evaluating people's actions presents notable difficulties. Numerous academics have addressed this matter by proposing the utilization of Deterrence theory, which promotes the implementation of severe penalties as a strategy to discourage such conduct (Parker, 1997; Bequai, 1998; Tudor, 2000; Kankanhalli et al., 2003). Nevertheless, scholars like Vance (2010) have proposed that the non-compliance of employees with information systems (IS) security protocols is not solely attributable to their apprehension of possible attacks.

2.4.6 Negligence or ignorance

In certain instances, employees within organizational settings may inadvertently fail to adequately prioritize adherence to security policies. In order to elucidate the phenomenon of users' neglect and ignorance, one can examine the occurrence of software piracy, which manifests when employees possess limited understanding of software installation as a result of diverse factors, such as inadequate training. The level of attribution by individuals to accidents involving the Islamic State (IS) is significant. The bulk of events are comprised of accidental breaches (Vroom and Solms, 2004). The consequences of ignorance or negligence in relation to Information Security Management Systems (ISMS) necessitate prompt and decisive action, which should be undertaken by specialists specializing in IS. Organizations allocate significant resources towards enhancing technical infrastructure in order to address this concern. However, the issues of ignorance and negligence are inherently human in nature and necessitate a distinct approach for resolution. Auditing individuals' behavior poses significant challenges. Several scholars have tackled this issue by suggesting the application of Deterrence theory, which advocates for the use of punitive measures as a means of deterring undesirable behavior (Parker, 1997; Bequai, 1998; Tudor, 2000; Kankanhalli et al., 2003). However, it has been suggested by researchers such as Vance (2010) that employees' failure to adhere to information systems (IS) security regulations cannot always be attributed only to their fear of potential threats.

2.4.7 Stress

The stress experienced by individuals in corporate settings can be attributed to factors such as heavy workloads and strict project deadlines. Individuals often experience anxiety when faced with stress and an excessive workload, regardless of any training program they may have undergone. The presence of stress has been found to contribute to the occurrence of errors made by individuals. However, individuals tend to disregard information security policies when they are experiencing high levels of stress. There exists a direct correlation between stress and fatigue and the vulnerabilities of information systems (Carstens et al., 2004). The presence of an imbalanced and excessive workload has been found to generate stress and additional strain for employees, so significantly diminishing both individual morale and organizational ethics (Kabay, 2002). The assignment of a substantial amount of labor imposes additional and undesired stress upon individuals, which is contrary to the ethical conduct of organizations. The occurrence of occurrences related to the Islamic State (IS) might be attributed to a moral and ethical breakdown, since individuals may see a lack of appreciation or worth (Kabay, 2002). It is imperative for organizations to implement measures that safeguard their personnel against both internal and external influences.

Indirect factors

These elements exert a significant influence on both the direct factors and the overall impact on Information Security Management Systems (ISMS).

2.4.8 Budgeting

The financial implications of managing organizations necessitate the need for sufficient budgetary planning in order to ensure their continued existence. It is well acknowledged among specialists in the field of information security that the budget allocated to an

organization has a notable influence on the effectiveness of its Information Security Management System (ISMS) (Al-Awadi and Renaud, 2007; Bazavam and Lim, 2007). In order to optimize the effectiveness of Information Security Management Systems (ISMS), it is imperative for organizations to implement an efficient cost strategy that adequately addresses both technological and personnel needs associated with ISMS. For example, the effective achievement of ISMS goals by organizations may be hindered if they have not created an access control system or provided their staff with a comprehensive training program. While it is essential for organizations to allocate resources towards information systems (IS), they may encounter challenges in sustaining a sufficient amount of spending.

2.4.9 Culture

The concept of organisational culture encompasses the fundamental principles, convictions, operational methodologies, mindset, conduct, standing, and ethical standards that shape the character of a business and its workforce. According to Dhillon (1997), the concept of information security culture (ISC) offers a framework for organizations to promote the safeguarding of information assets through the cultivation of appropriate behaviors. However, it has been contended by several authors that ISC is a matter of management and is unable to be definitively ascertained (Ruighaver et al., 2007). In order to illustrate the implementation of Information Security Culture (ISC) within organizations, one might examine the case of a security policy. This policy serves as a guiding framework that employees adhere to, thereby fostering an ingrained culture of security within the broader organizational context. The involvement and endorsement of management are crucial in order to facilitate the promotion of Information Security Culture (ISC), hence improving the efficacy of security policy execution (Lim et al., 2010). This objective can be accomplished through the implementation of comprehensive and impactful awareness campaigns, training initiatives, and educational programs.

2.4.10 Communication

Exchange of knowledge and thoughts among the members of an organization and those outside of it is what we mean when we talk about "communication." Having the ability to effectively communicate ensures that messages reach their intended recipients. The evolution of technological advances in communication and information has resulted in having an essential role in computer security (Dhillon and Backhouse, 2000). There are several ways to convey information, such as verbal interaction, written (both electronically and manually) correspondence, and others. It can be used to raise staff morale and encourage them to pay attention to IS security rules. Proper interaction between management and staff is essential for enforcing a culture of IS security. After that, it's important to include everyone in the organization, regardless of their position, in your communications (Pattinson and Anderson, 2007). Security training seminars, electronic mail, the telephone, and in-person conferences are all valid modes of contact. Using the ISMS as an example, people can show how crucial secrecy is when two persons from different organizations exchange emails. It is the responsibility of the employer to make clear to employees what kinds of information can be shared with outside parties without compromising privacy.

2.4.11 Security policy enforcement

A security policy is an official document within an organization that establishes the rules and regulations pertaining to information security. According to Tipton and Krause (2008), it is imperative for staff at all levels within organizations to possess a comprehensive understanding of the security policy and actively engage in its execution in accordance with their respective roles and responsibilities. The application of the security strategy poses a significant challenge for Information Security Management Systems (ISMS) and necessitates management support for its execution (Tipton and Krause, 2008).

2.4.12 Management support

To ensure the effective implementation of Information Security Management Systems (ISMS) within organizations, it is imperative that leadership provide assistance across the whole lifecycle, encompassing the planning phase through to the review stage. The function of leadership within the Information Security Management System (ISMS) extends beyond mere advocacy, encompassing the responsibility to effectively communicate the IS security policy to the entire organization. One prominent illustration of management support for Information Security Management Systems (ISMS) within organizations is the provision of sufficient budgetary resources, which is solely overseen by senior management. According to Fung and Jordan (2002), upper management generally holds the belief that the duty of (ISMS) lies solely with the IT staff. This belief is based on the understanding that the IT team is responsible for implementing suitable software systems that effectively safeguard data security. In order to secure the complete support of senior management for the Information Security Management System (ISMS) within the organization, it is imperative to educate them on the clear correlation between information security and the core operations of the organization. As a result, the allocation of resources and the implementation of the information security policy, which necessitates the endorsement of top-level executives, will be effectively accomplished (Von Solms, 1999).

3 Empirical part

This part of the thesis is devoted to empirical part where the author explains that approach taken to discover the objective of the thesis.

3.1 Design of the research

The research is based on the composite indicators that are constructed on various statements in regards of a certain topic of cyber security and how a chosen company approaches such a topic. Further, the author tests the validity and reliability of employee's responses. The structure of the questions See, ["Survey design"](#).

3.1.1 Hypothesis/assumptions

Experience might positively impact the "Privacy concern of a firm". If a user had a previous experience with hacking and his/her personal data was stolen, there is a higher probability that employees would be more cautious about strange emails, connections and etc. Hence:

H0: There is a positive correlation between the experience of a user and privacy concern of a firm.

H1: There is not a positive correlation between the experience of a user and privacy concerns of a firm.

Negligence and Ignorance would be negatively correlated with the "Privacy concerns of a firm". If employees do not pay a close attention to suspicious messages, usage of unknown Wi-Fi connection and etc. That would potentially lead to a higher risk of cyber – attacks to a small company. Hence:

H0: There is a negative correlation between the "Negligence and Ignorance" of a user and privacy concern of a firm.

H0: There is not a negative correlation between the "Negligence and Ignorance" of a user and privacy concern of a firm.

Incentive policies and proper budgeting might decrease the risk of cyber – attacks. If company provides with the bonuses, recognitions and awards for a proper conduct and invests money into proper IT tools that could prevent such attacks, that would potentially decrease the risk of attacks.

H0: There is a positive correlation between the "Incentive policy and budgeting" and "Privacy concerns of a firm".

H0: There is not a positive correlation between the "Incentive policy and budgeting" and "Privacy concerns of a firm".

3.1.2 Methods used for validation

The author relies on statistical analysis between constructed variables. There are two types of variables, dependent and independent. Since the data doesn't have any increasing or decreasing trend, the author uses Ordinary Regression Analysis, where all variables are transferred into the (*Log*) function. In order to validate the relationship between variables, the author applies a Pearson correlation analysis, which ranges from -1 up to 1, See Figure – 3.

Figure 3: Pearson correlation.

Scale of correlation coefficient	Value
$0 < r \leq 0.19$	Very Low Correlation
$0.2 \leq r \leq 0.39$	Low Correlation
$0.4 \leq r \leq 0.59$	Moderate Correlation
$0.6 \leq r \leq 0.79$	High Correlation
$0.8 \leq r \leq 1.0$	Very High Correlation

Source: Jayabalan (2020)

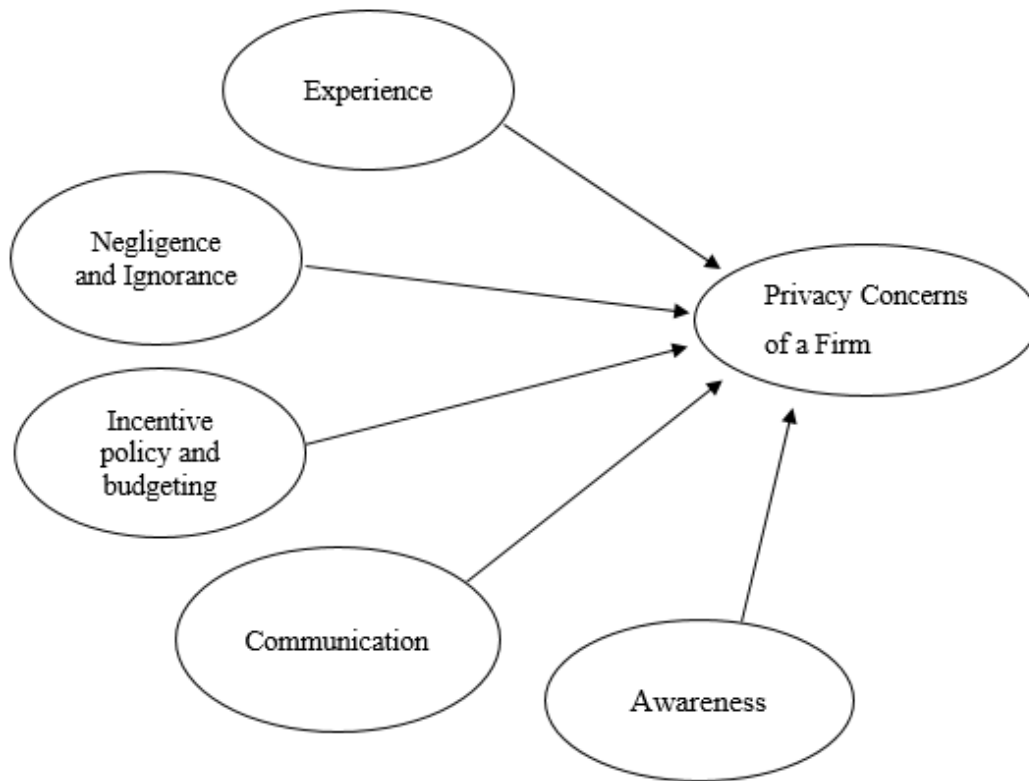
In order to assess the validity and reliability of the answers, the author uses the Cronbach's alpha test. The measures are the following, See Figure – 4.

Figure 4: Cronbach's alpha measure

<i>Cronbach's Alpha Score</i>	<i>Level of Reliability</i>
0.0 – 0.20	Less Reliable
>0.20 – 0.40	Rather Reliable
>0.40 – 0.60	Quite Reliable
>0.60 – 0.80	Reliable
>0.80 – 1.00	Very Reliable

Source: Ahbika (2017).

3.1.3 Potential model without numeric values



Source: Own proposal.

The above model depicts the independent variable and dependent variables in the statistical model. The “Privacy concerns of a firm” is being dependent variables and the rest of are independent variables.

3.1.4 Company’s info

The research is run in the Czech company called “TBM Group” which operates in the conference business. The main core of the business is to organize business meetings with the top-level management to discuss certain issues of a certain industry.

Picture: 1: TBM Evolution logo



Source: [tbmgrouptm.com/](https://www.tbmgrouptm.com/) (2023)

There are over 300 employees overall and the company operates in two countries, Czech Republic and Macedonia.

TBM Group is dedicated to crafting meaningful and pertinent events that address the most critical issues across various industries. Each event is meticulously developed using data derived from thorough market analysis, extensive interviews with leading industry professionals, and various business intelligence tools. The comprehensive approach employed by TBM Group enables the creation of high-profile business-to-business meetings that cater to the current and pressing needs of business leaders. By incorporating innovative insights and best practices from each industry, the organization aims to equip event attendees with practical information, valuable insights, and beneficial contacts.

In the past year alone, TBM Group has successfully orchestrated over 40 business events spanning six different countries. The company specializes in organizing business events in sectors such as energy, automotive, IT, chemical, medical devices, pharmaceuticals, tax, banking, and sports hospitality. Furthermore, TBM Group remains flexible and open to tailoring custom events for individual businesses through its webinar division, with the overarching objective of providing clients with the business information and market access they require.

3.1.5 Demographical data of employees

The following table represents the demographical data of all respondents from TBM Group.

Table 4: Demographical data of respondents

Gender		N - 162
Male	91	56,17%
Female	71	43,83%
Age		
15 – 25	53	32,72%
26 – 35	41	25,31%
36 – 45	45	27,78%
46 – 55	15	9,26%
55 +	8	4,94%
Department		
Sales and Marketing	95	58,64%
Finance and accounting	12	7,41%
Production	25	15,43%

IT	30	18,52%
----	----	--------

Source: Own processing.

From the table above, it is seen that there are most males (56 %) and female accounted for (44 %). The age group is divided in the following way, there are 33 % of people aged (15-25), followed by 28 % of people aged (36-45), followed by 25 % of people aged (26-35), followed by 9 % of people aged (46-55) and only 5 % of people aged (55+). Due to the fact that the company's core business is to organize conference business, there is a prevalence of workers who are involved in sales and marketing (59 %), followed by IT specialists (19 %), finance and accounting (7 %) and production (15 %).

3.1.6 Descriptive analysis of variables

The chapter is devoted to demonstrate the data which was gathered with the help of "Online – Survey". There were 162 participants overall. The descriptive statistics of each dimension will be presented below.

However, before we dive into the descriptive analysis, there is a list of abbreviations with all variables, **Ave** stand for average.

PCFAve – Privacy Concerns of a Firm (TBM Group)

CMAve – Communication

EXPave – Experience

INPAve – Incentive Policy and Budgeting

NaIAve - Negligence and Ignorance

AWRAve – Awareness

Table 5: Descriptive statistics

	N	Minimum	Maximum	Mean	Std. Deviation	Skewness		Kurtosis	
	Statistic	Statistic	Statistic	Statistic	Statistic	Statistic	Std. Error	Statistic	Std. Error
PCFAve	162	1.00	5.00	2.1321	1.02148	.544	.449	-.474	.587
CMAve	162	1.00	5.00	1.4002	.62380	1.744	.449	4.724	.587
EXPave	162	1.00	5.00	3.3034	.88217	.594	.449	-.039	.587
INPAve	162	1.00	5.00	3.4201	.82318	.653	.449	-.062	.587
NaIAve	162	1.00	5.00	1.2204	1.20217	.114	.449	-.039	.587
AWRAve	162	1.00	5.00	0.1978	.82318	.253	.449	-.062	.587
Valid N (listwise)	162								

Source: Own processing, SPSS IBM.

If we look at the mean of each variable, we could see that most of the participants do understand the relevance of “Privacy concerns of a firm”, “Communication”. In terms of experience, the mean equals to 3.3, which indicates that people probably had no idea whether they had any suspicious email in their previous workplaces, that might undermine the security of a firm eventually. Also, the “Incentive Policy and Budgeting” equals to 3.4, which indicates that probably the TBM Group doesn’t pay too much attention to recognition of its own employees, and even riskier, that it doesn’t invest enough funds to protect it-self from various dangerous emails.

However, there is a must to see whether the variables are normally distributed., the author runs the Normality test.

Table 6: Test of Normality

Tests of Normality						
	Kolmogorov-Smirnova			Shapiro-Wilk		
	Statistic	df	Sig.	Statistic	df	Sig.
PCFAve	.229	162	.000	.948	162	.000
CMAve	.245	162	.000	.762	162	.000
EXPAve	.041	162	.000	.949	162	.000
INPAve	.343	162	.000	.892	162	.000
NaIAve	.411	162	.000	.756	162	.000
AWRAve	.422	162	.000	.882	162	.000

a. Lilliefors Significance Correction

Source: Own processing.

Based on the results, if we look at the significance level of all variables, the significance level of $p - value$ equals to .000, which is less than *.05 alpha level*. Hence, the variables are *not normally* distributed thus, the “**Ordinary Regression Analysis**” should be applied.

It is necessary for the author to include the variables into the Log function, as shown below. It is clear from the table that follows that the variables continue to be distributed in a non-normal manner.

Table 7: log-in Normality

Tests of Normality						
	Kolmogorov-Smirnova			Shapiro-Wilk		
	Statistic	df	Sig.	Statistic	df	Sig.
log_PCFAve	.001	162	.000	.897	162	.000
log_CMAve	.104	162	.000	.897	162	.000
log_EXP Ave	.201	162	.000	.857	162	.000
log_INPAve	.302	162	.000	.982	162	.000
log_NaIAve	.074	162	.000	.789	162	.000
log_AWRAve	.051	162	.000	.940	162	.000

a. Lilliefors Significance Correction

Source: Own processing, based on SPSS IBM.

3.1.7 Test of Fit – Model

Further, there is a need to apply the Ordinal Regression Analysis to see whether the data fits the model.

Model Fitting Information

Model	-2 Log Likelihood	Chi-Square	df	Sig.
Intercept Only	955.317			
Final	458.687	197.978	5	.000

Link function: Logit.

Source: Own processing, based on SPSS IBM.

A greater p-value indicates that the data are a good match for the model since the significance threshold is between .001 and .05, which indicates that the p-value is higher. The model has a major statistical contribution.

3.1.8 Cronbach's alpha

Before running the correlation analysis, there is a must to check the internal reliability of participant's answers. If any dimensional variables get a number less than 60 % of reliability, the dimension should be excluded from the modelling Ahbika (2017).

Table 8: Reliability test

Cronbach's Alpha for "Privacy Concerns".	N of Items
.884	4
Cronbach's Alpha for "Awareness"	N of Items
.731	4
Cronbach's Alpha for "Communication".	N of Item
.718	3
Cronbach's Alpha for "Incentive Policy and Budgeting".	N of Item
.645	4
Cronbach's Alpha for "Negligence and Ignorance".	N of Item
.845	4
Cronbach's Alpha for "Experience".	N of Item
.814	4

Source: Own processing, based on SPSS IBM.

Based on the results of Cronbach's alpha, we could see that all values are higher than .60 %, which indicates that the internal reliability of participants answers are on a descent level. However, the lowest number again is shown as "Incentive Policy and Budgeting".

3.1.9 Correlation Analysis

Correlations

		log_PC FAve	log_C MAve	log_EX PAve	log_IN PAve	log_N aIAve	log_AW RAve
Privacy Concern	Pearson Correlation		.215	.684	.150	-.651	.822
		.1					
	Sig. (2-tailed)		.055	.102	.185	.102	.085
	N	162	162	162	162	162	162
Communi- cation	Pearson Correlation	.215	1	-.319	-.037	-.231	-.031
	Sig. (2-tailed)	.055		.051	.813	.030	.053
	N	162	162	162	162	162	162
Experienc- e	Pearson Correlation	.684	-.319	1	.316**	.051	.399
	Sig. (2-tailed)	.102	.051		.004	.042	.001
	N	162	162	162	162	162	162
Incentives and Budgeting	Pearson Correlation	.150	-.037	.336**	1	-.516	.056
	Sig. (2-tailed)	.185	.813	.004		.072	-.415
	N	162	162	162	162	162	162
Negligence and Ignorance	Pearson Correlation	-.651	-.231	.051	-.516	1	-.506
	Sig. (2-tailed)	.102	.030	.042	.072		.045
	N	162	162	162	162	162	162
Awareness	Pearson Correlation	.822	-.031	.399	.056	-.506	1
	Sig. (2-tailed)	.085	.053	.001	-.415	.045	
	N	162	162	162	162	162	162

Source: Own processing, based on SPSS IBM.

There is a positive and negative correlation among dependent and independent variable. Meaning that some of the hypothesis could already be confirmed. From the table we could see a strong positive correlation between the “Awareness” and “Privacy concerns of a firm” which is 82 %. There is also a quite strong positive correlation between “Experience” and “Privacy Concerns of a Firm”, which equals to 68 %. Interestingly enough, the “Negligence and Ignorance” has a negative correlation with the “Privacy concern” which equals to -65 %.

3.1.10 Parameters of the model

Following the completion of all of the analysis. In other words, the "Model of Fit" is statistically significant, which indicates that the author was able to construct a final model that included the coefficients for each independent variable and the influence that each variable had on the dependent variable. When the author follows these steps, they are able to construct a final model that includes the correlation of all of the variables.

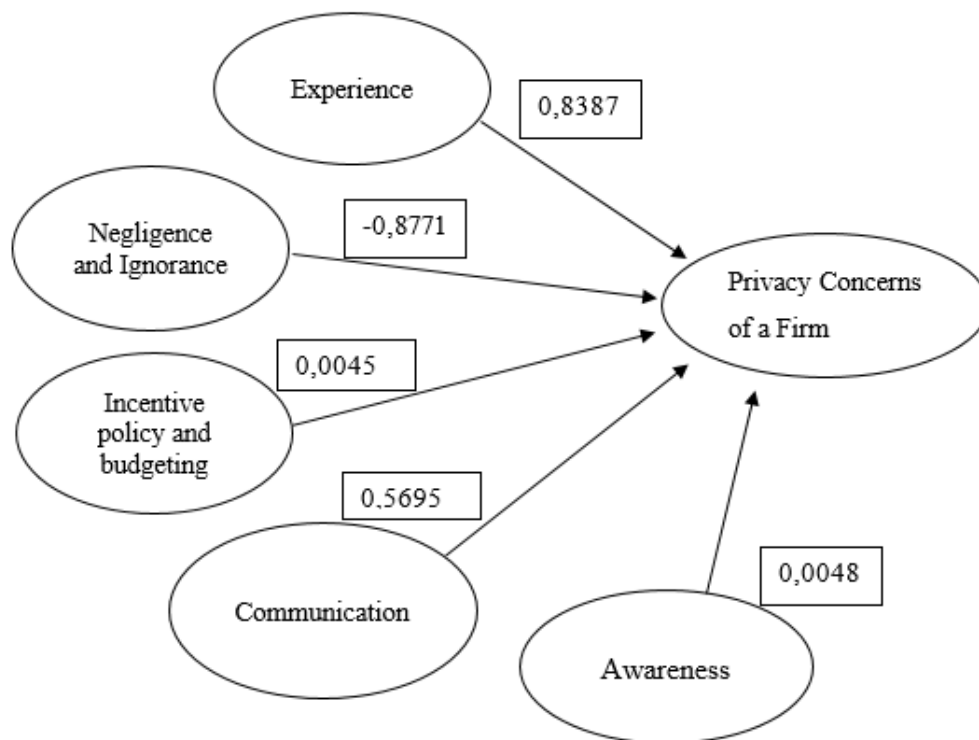
Table 9: Parameters of the final model

Parameter		B	Std. Error	95% Wald Confidence Interval		Wald Chi-Square	Sig.
				Lower	Upper		
Threshold	[Prodlog=1.00]	-6,7456	1,6006	-9,0003	-2,5009	12,3447	0,04457
	[Prodlog=1.33]	-3,8897	1,5285	-6,8106	-0,8910	6,4554	0,0110
	[Prodlog=1.67]	-1,9688	1,4626	-4,6012	1,1062	1,4458	0,2287
	[Prodlog=2.00]	-0,5587	1,4489	-3,4908	2,1000	0,2072	0,6490
	[Prodlog=2.33]	-0,0567	1,8807	-2,8079	2,8046	0,0077	0,9963
	[Prodlog=2.67]	1,6832	1,6006	-1,4606	4,5601	1,0551	0,2945
CMAve			0,5695	-1,7605	-0,3500	7,3556	0.0145
EXP Ave			0,8387	-1,4867	-0,1230	8,6812	0.0003

INPAve	0,0045	-1,4606	1,7701	4,5166	0.0132
NaIAve	-0,8771	1,5007	1,5660	2,1506	0.0021
AWRAve	0,0048	-0,4661	1,7788	3,1929	0.0401
(Scale)	1 ^a				

Source: Own processing, SPSS IBM.

Figure 5: Final Model with numeric values



Source: Own proposal.

The numbers are taken as parameters from the Table – 9, colored in red. All variables are statistically significant with ***p – value*** lower than .05 alpha level. We see that the highest impact on “Privacy of a firm” has the “Experience” of employees with the 0.8387. Negligence however, has a negative impact on the “Privacy concerns of a firm” and “Communication” has the moderate increasing probability of 0.5695. Meaning that, a stronger communication would lead to a more protected company and avoid different types of attacks. Experience as well has an increasing probability towards Privacy Concerns of a Firm.

The “Awareness” and “Incentive Policy and Budgeting” have weak positive correlation towards “Privacy Concerns of a Firm” which might indicate that “Incentive Policy and Budgeting” isn’t applied in the TBM Group, or with a smaller extent. The same applies for “Awareness”.

Figure 6: Results of hypothesis

Hypothesis	Accepted / Rejected
There is a positive correlation between the experience of a user and privacy concern of a firm.	Accept
H0: There is a negative correlation between the “Negligence and Ignorance” of a user and privacy concern of a firm	Accept
There is a positive correlation between the “Incentive policy and budgeting” and “Privacy concerns of a firm”.	Accept

Source: Own proposal.

Based on the results of our model, there were 2 hypotheses confirmed out of 3. The last hypothesis didn't show a strong correlation between “Incentive policy and budgeting” and the Privacy concerns of a firm”. Even though, the correlation was positive, it was relatively weak, thus, couldn't fully confirm by the realm of data.

4 Discussions

4.1 Awareness and Experience as Significant Factors

The study identified a robust positive correlation between the awareness of employees about cyber-attacks and their previous experiences with such attacks, suggesting a strong link between these variables and the privacy concerns of the company. This finding aligns with the literature emphasizing the importance of employee knowledge and experience in shaping organizational cybersecurity posture (Nkhoma, 2008; Cobb & Kaybay, 2002). The company should acknowledge the pivotal role of cultivating a cyber-aware culture and fostering experiences that enhance employees' understanding of potential threats.

Based on the Cronbach's alpha level, the result demonstrates quite a strong reliability, which indicates that participants seem to have a high level of awareness regarding cyber-attacks, which aligns with the positive correlation found in the study between awareness and privacy concerns. This suggests that the awareness levels among employees may indeed be influencing the overall privacy concerns of the company.

4.2 Negligence and Ignorance

The negative correlation observed between negligence and ignorance of employees and privacy concerns is noteworthy. It implies that a reduction in employee negligence and ignorance can contribute to a lower level of privacy concerns within the organization. This underscores the significance of implementing strategies to address and mitigate employee apathy and lack of awareness regarding cybersecurity measures.

4.3 Incentive Policies and Budgeting

The relatively weak correlation between incentive policies and budgeting for employee training and privacy concerns highlights a potential area for improvement. Organizations should reassess their investment in training programs, recognition initiatives, and incentive structures to bolster employee engagement in cybersecurity practices. Strengthening these aspects can enhance the effectiveness of cybersecurity measures and contribute to a more secure ICT environment.

4.4 Communication and IT Department Support

The positive correlation between communication levels and privacy concerns suggests that a high level of communication and support from the IT department correlates with

increased privacy concerns. While this may seem counterintuitive, it could indicate that increased communication is a response to heightened cybersecurity threats. Further exploration is needed to understand the dynamics of this relationship and to ensure that communication efforts are effectively reducing privacy concerns rather than exacerbating them.

4.5 Recommendations

In regards of “Incentive policies and Budgeting” the author recommends to apply the following steps:

- Review and update incentive policies to ensure they align with cybersecurity objectives.
- Allocate sufficient budget for ongoing training and development programs.
- Recognize and reward employees who actively contribute to the organization's cybersecurity posture.
- Provide the employees with trainings and show – cases where different attack – scenarios will be introduced with the potential consequences.

Conclusions

This bachelor thesis has delved into the critical realm of human factors as threats to the information and communication technology (ICT) security of companies. The statistical model developed, with a commendable Cronbach's alpha of 80%, revealed valuable insights into the dynamics shaping the privacy concerns within organizations.

The positive correlation identified between awareness of employees about cyber attacks and their previous experiences with such attacks underscores the pivotal role of cultivating a cyber-aware culture. It is evident that a well-informed workforce contributes significantly to the reduction of privacy concerns.

Furthermore, the negative correlation between negligence and ignorance of employees and privacy concerns highlights the importance of addressing apathy and lack of awareness within the workforce. Initiatives aimed at reducing negligence and fostering a proactive cybersecurity culture are imperative.

The relatively weak correlation associated with incentive policies and budgeting for training suggests an area for improvement. Organizations are recommended to reassess their investments in training programs, recognition initiatives, and incentive structures to bolster employee engagement in cybersecurity practices.

Interestingly, the positive correlation between communication levels and privacy concerns may necessitate further investigation. While a high level of communication is generally positive, understanding the nuances of this relationship is crucial to ensure that communication efforts are effectively reducing privacy concerns.

In light of these findings, recommendations have been outlined to strengthen employee awareness, mitigate negligence and ignorance, enhance incentive policies and budgeting, and optimize communication and IT department support. These recommendations provide practical steps for organizations to bolster their cybersecurity posture and reduce privacy concerns.

This study contributes to the ongoing discourse surrounding cybersecurity in organizations, emphasizing the critical role of human factors in shaping the security landscape. As the cybersecurity landscape continues to evolve, ongoing research and adaptive strategies will be essential for organizations to stay resilient against the myriad of cyber threats.

List of references

1. Bruce Schneier. Secrets and lies. Robert Ipsen, 2000.
2. William L. Simon Kevin D. Mitnik. The Art of Deception. Wiley Publishing, Inc., 2002.
3. Hewitt, Nick. Information Security: The Ultimate Guide. Imperva [online]. 2020-11-09 [cit. 2023-02-06]. Available at: <https://www.imperva.com/learn/data-security/information-security-infosec/>
4. Huvila, Isto. Information work analysis: an approach to research on information interactions and information behavior in context. Information Research [online]. 2008-09 [cit. 2023-02-13]. Available at: <http://informationr.net/ir/13-3/paper349.html>
5. Hadnagy, Christopher J. Social Engineering: The Science of Human Hacking, 2nd Edition. 2. Arizona, USA, 2018. ISBN 978-1-119-43338-5.
6. Aghaunor, Gabriel. Factors Influencing the Implementation of Information Security Risk Management: A case study of Nigerian Commercial Banks. Luleå University of Technology [online]. 2022 [cit. 2023-02-07]. Available at: <https://www.diva-portal.org/smash/get/diva2:1672230/FULLTEXT01.pdf>
7. Alexander, John. Risk, Threat, or Vulnerability? How to Tell the Difference. KENNA [online]. 2021-28-01 [cit. 2023-02-06]. Available at: <https://www.kennasecurity.com/blog/risk-vs-threat-vs-vulnerability/>
8. Collins, K. (2015): Here's what your stolen identity goes for on the internet's black market. Retrieved from <https://qz.com/460482/heres-what-your-stolen-identity-goes-for-on-the-internets-black-market>
9. Curry, Michael. InfoSec Process Action Model (IPAM): Systematically Addressing Individual Security Behavior [online]. ACM SIGMIS Database, 2018 [cit. 2023-02-06]. Available at: doi:10.1145/3210530.3210535
10. Policie České republiky: Jednotlive druhy kyberkriminality [online]. Praha, 2022 [cit. 2023-05-01]. Available at: <https://www.policie.cz/clanek/jednotlive-druhy-kyberkriminality.aspx>
11. Hatch, Brian; Lee, James; Kurtz, George. Hacking bez tajemství: Linux. 1. vydání. Brno: Computer Press, 2003. 644s. ISBN 80-7226-869-4.
12. ITIL security management: Security management [online]. 2023 [cit. 2023-04-30]. Available at: https://www.wikiwand.com/en/ITIL_security_management?fbclid=IwAR1dnLdNq7gQfZirsBEMMdLx0Be7MFtpUnEgqK5v0RG1PMRu3kK5O0ExQUc
13. TOO HILL, Ryan. 20 Phishing Email Examples: And What Not To Fall For In 2023. AURA [online]. 2023-01-19 [cit. 2023-02-28]. Available at: <https://www.aura.com/learn/phishing-email-examples>
14. POŽÁR, Josef, 2019. Vybrané trendy kybernetické kriminality. Acta Informatica Pragensia [online]. 4(3), 336–348. ISSN 18054951, 18054951. Dostupné z: doi:10.18267/j.aip.80
15. JIŘÍK, Pavel. 3 Examples of Typical Smishing and Vishing Attacks in 2022. PHONEXIA [online]. 2022-08-08 [cit. 2023-03-15]. Dostupné z: <https://www.phonexia.com/blog/3-examples-of-typical-smishing-and-vishing-attacks-in-2022/>
16. Lee J. and Lee Y. 2002. 'A holistic model of computer abuse within organizations'. Information management & computer security, 10(2/3): 57-63

17. Willison, R. (2006) Understanding the perpetration of employee computer crime in the organisational context. *Information and Organization*, 16, 304-324.
18. Islam, S. and Dong, W. (2008), Human Factors in Software Security Risk Management, In: *Proc. of the 1st International Workshop on Leadership and Management in Software Architecture (LMSA.08)*, ACM Press, 2008, Leipzig, Germany.
19. Jahankhani, H., Mouratidis, H., Nkhoma, M.Z., (2008), Management versus security specialists: an empirical study on security related perceptions, *Information Management & Computer Security*, Vol. 16 Iss: 2 pp. 187 – 205
20. Avizienis, A., Laprie, J. C., Randell, B. & Landwehr, C. (2004) Basic concepts and taxonomy of dependable and secure computing. *Dependable and Secure Computing*, *IEEE Transactions on*, 1, 11-33.
21. Denis Besnard, Budi Arief. Computer security impaired by legitimate users. *Computers and Security*, 2004, 23 (3), pp. Pages 253-264. Available at: [ff10.1016/j.cose.2003.09.002](http://dx.doi.org/10.1016/j.cose.2003.09.002)
22. Rescorla, E. 2003. Security holes...Who cares? Paper presented at the Proceedings of the 12th USENIX Security Symposium, Washington, D.C.
23. Schaufeli, W. (2007) Burnout in Health Care. In: Carayon, P., Ed., *Handbook of Human Factors and Ergonomics in Health Care and Patient Safety*, Lawrence Erlbaum, Mahwah, 217-232.
24. Cobb, C., Cobb, S., & Kaybay, M. E. (2002). Penetrating Computer Systems. In S. Bosworth & M. D. Kabay (Eds.), *Computer Security Handbook* (4th ed., pp. 8.1-8.34). New York: John Wiley & Sons
25. Wilson, M. & Hash, J. (2003) Building an Information Technology Security Awareness and Training Program. In Commerce, U. S. D. O. (Ed. Washington, National Institute of Standards and Technology (NIST).
26. Puhakainen, P. (2006) Design Theory for Information Security Awareness. Olulu, University of Oulu.
27. Mikko, T. & Siponen (2000) A conceptual foundation for organizational information security awareness. *Information Management & Computer Security*, 8, 31-41.
28. Aytes, K. & Cnnolly, T. (2003) A Research Model for Investigating Human Behavior Related to Computer Security. Ninth Americas Conference on Information Systems.
29. Bulgurcu, B., Cavusoglu, H. & Benbaasat, I. (2009) Roles of information Security Awareness and Perceived Fairness in Information Security Policy Compliance. European and Mediterranean Conference on Information Systems (AMCIS). Turkey, Izmir, Late Breaking Paper.
30. Sarkar, A. (2010) Assessing Vulnerability and Adaptation of Arsenic Exposed Population in India, *Asian Journal of Water, Environment and Pollution*. 7(1): 35-43.
31. Ernst & Young (2008) 10th Annual Global Information Security Survey Achieving a Balance of Risk and Performance. Ernst & Young

Appendices

- 1) What is your gender?
 - a) Male
 - b) Female

- 2) What is your age?
 - a) 15 – 25
 - b) 26 – 35
 - c) 36 – 45
 - d) 46 – 55
 - e) 55 +

- 3) What department you work in?
 - a) Sales and Marketing
 - b) Finance and accounting
 - c) Production
 - d) IT

Privacy Concerns of a Firm

Statements	1	2	3	4	5	Source
The company has got a special IT plan that should be followed when suspicious messages recieved.						Jahankhani, Mouratidis and Nkhoma, (2008) Aytes, & Cnnolly, (2003)
There is a special training that employees should go thru to receive a certification on “Privacy”.						
There is a double – authorization option to log – into the company’s data server.						
There is quick IT support if it is needed.						

Negligence and Ignorance

Statements	1	2	3	4	5	Source
I do not use the two-factor – authentication (a password and a confirmation code) to log-in to my personal account. (rev)						Brandimarte, Acquisti, & Loewenstein (2013).
If there is an available Wi-Fi connection, I am sure to be connected to such, however I understand that it is risky. (rev)						
I read messages that pops – up sometimes for better understanding. (rev)						
I use my social media while being connected to the company's network. (rev)						Rescorla (2003)

Experience

Statements	1	2	3	4	5	Source
I previously had an experience with the hacking and my data was stolen.						Cobb & Kaybay (2002).
I use my social media at my work place but only on my personal gadget/PC/laptop.						
I never open suspicious emails because I once had a malware due to that.						

Incentive policy and budgeting

Statements	1	2	3	4	5	Source
I had received a recognition from IT department due to fulfilled IT course.						Bulgurcu, Cavusoglu & Benbaasat (2009)
There is an incentive in the company for taking care of necessary data.						
There is an official document in the company in regards of "Security policy".						
The company invests into security enough money based on the tools that employees have.						

Communication

Statements	1	2	3	4	5	Source
The IT team always warns us if there is any suspicious email around the company and what to do.						Aytes & Cnnolly (2003)
The IT team is supportive 24/7, I fully rely and trust in their support.						
There is an option to encrypt the employee's chat.						

Awareness

Question	1	2	3	4	5	Source
I am aware that there are tons of cyber – attacks and many companies are being a subject of such attacks.						Aytes, & Cnnolly (2003)
I am aware about “Privacy concerns of the company I work for”						
I wouldn't share any personal data with the unknown user or send it to somebody I don't know.						
I would share personal data only, if there is a “Green lock pad” on the screen.						Rescorla (2003)